

MIRROU — EU AI Act & Compliance Framework

Performance Creative Studio | Hamburg & Berlin

Dokument-Typ: Regulatorisches Framework **Version:** 1.0 | Mai 2026 **Geltungsbereich:** Alle KI-gestützten Creative-Produktionen **Rechtsgrundlage:** Verordnung (EU) 2024/1689 (EU AI Act), DSGVO, Data Act

1. Regulatorischer Kontext

1.1 EU AI Act — Timeline & Relevanz

Datum	Meilenstein	Relevanz für MIRROU
1. August 2024	Inkrafttreten der Verordnung	Planungsphase
2. Februar 2025	Verbotene KI-Praktiken (Art. 5)	Keine Relevanz (Werbung nicht verboten)
2. August 2025	Anforderungen an GPAI-Modelle (Art. 52)	Relevanz für verwendete KI-Modelle
2. August 2026	Vollständige Anwendbarkeit (Art. 6, 50, 52)	Kern-Deadline für MIRROU
2. August 2027	Hohe-Risiko-Systeme (Art. 6)	Relevanz bei Erweiterung in HR/ Recruiting

1.2 Anwendbarkeit auf MIRROU

KI-System nach Art. 3 EU AI Act:

- MIRROU nutzt KI-Modelle (Midjourney, DALL-E, Stable Diffusion, Custom GPT) zur Generierung von Werbeeinhalten
- Diese Inhalte werden kommerziell genutzt (Werbung für Dritte)
- Einstufung:** Limited-Risk-KI-System (Art. 50) — Transparenzpflichten

Keine High-Risk-Einstufung:

- Keine KI-Systeme in sensiblen Bereichen (Gesundheit, Recht, Bildung)
- Keine biometrische Identifikation
- Keine Manipulation oder Social Scoring

2. Compliance-Architektur

2.1 Governance-Struktur

Compliance Officer (CO)
└─ KI-Risiko-Assessment
└─ Dokumentation & Audit-Trail
└─ Kunden-Kommunikation
└─ Regulatorisches Monitoring

- KI-Operator (KO)

└─ Tool-Auswahl & -Konfiguration

└─ Prompt-Engineering & -Dokumentation

└─ Output-Review & -Freigabe

└─ Labeling & Metadaten-Management
- Creative Lead (CL)

└─ Künstlerische Direction

└─ Menschliche Review & Freigabe

└─ Qualitätskontrolle

└─ Kunden-Freigabe-Prozess

2.2 Rollen & Verantwortlichkeiten

Rolle	Verantwortlichkeit	Qualifikation
Compliance Officer	Gesamte Compliance-Strategie, Audit-Readiness, Kunden-Beratung	Rechtswissenschaftliches Studium, KI-Recht-Zertifizierung
KI-Operator	Technische Umsetzung, Tool-Management, Prompt-Dokumentation	KI/ML-Background, Prompt-Engineering-Expertise
Creative Lead	Künstlerische Qualität, menschliche Oversight, Kunden-Freigabe	5+ Jahre Creative Direction, Brand-Expertise

3. Transparenzpflichten (Art. 50 EU AI Act)

3.1 Pflicht zur Offenlegung

- Art. 50 Abs. 1:** Bei der Bereitstellung von KI-Systemen, die mit Menschen interagieren, müssen diese darüber informiert werden, dass sie mit einer KI interagieren.
- Art. 50 Abs. 2:** Bei der Bereitstellung von KI-generiertem Content müssen die Outputs als solche gekennzeichnet werden.
- Art. 50 Abs. 3:** Ausnahme: Wenn der Content einer substantiellen menschlichen Nachbearbeitung unterliegt.

3.2 MIRROU-Labeling-Standards

Content-Typ	KI-Anteil	Labeling-Pflicht	MIRROU-Standard
Reine KI-Generierung	100%	Ja	„AI-Generated” + Wasserzeichen
KI + substantielle menschliche Nachbearbeitung	60-99%	Nein (Ausnahme Art. 50 Abs. 3)	„AI-Assisted” (freiwillig)

Table 3 – continued

Content-Typ	KI-Anteil	Labeling-Pflicht	MIRROU-Standard
KI-Enhancement (Foto + KI-Hintergrund)	20–59%	Nein	„AI-Assisted“ (freiwillig)
Reine Fotografie	0%	Nein	„100% Human-Crafted“ (auf Anfrage)

3.3 Labeling-Implementierung

Technische Umsetzung:

- **EXIF-Daten:** Jeder Asset enthält Metadaten mit KI-Usage-Flag
- **Wasserzeichen:** Bei 100% KI-Generierung: diskretes „AI-Generated“-Wasserzeichen
- **Dokumentation:** Separater AI-Usage-Report pro Projekt
- **Kunden-Kommunikation:** Klare Kommunikation in Briefing und Vertrag

Beispiel-Labeling:

```
Asset: luminous_aura_hero_v1.jpg
KI-Anteil: 35% (Hintergrund generiert, Produkt fotografiert,
             menschliche Nachbearbeitung: Farbkorrektur, Compositing)
Label: AI-Assisted
Compliance-Status: Konform (Art. 50 Abs. 3)
Reviewer: [Name Creative Lead]
Datum: 2026-05-15
```

4. Dokumentationspflichten

4.1 Technische Dokumentation (Art. 11 EU AI Act)

Dokument	Inhalt	Verantwortlich	Aufbewahrung
KI-System-Beschreibung	Verwendete Modelle, Versionen, Konfigurationen	KI-Operator	3 Jahre
Prompt-Log	Alle verwendeten Prompts (anonymisiert)	KI-Operator	3 Jahre
Output-Log	Alle generierten Outputs mit Metadaten	KI-Operator	3 Jahre
Review-Log	Menschliche Reviews, Freigaben, Korrekturen	Creative Lead	3 Jahre
Kunden-Kommunikation	Briefings, Freigaben, AI-Usage-Reports	Compliance Officer	3 Jahre
Trainingsdaten-Dokumentation	Quellen, Lizenzen, DSGVO-Konformität	KI-Operator	3 Jahre

4.2 Audit-Trail-Struktur

```
Projekt: [Projekt-Name]
Kunde: [Kunden-Name]
Datum: [Zeitraum]

Schritt 1: Briefing & Risiko-Assessment
├─ KI-Risiko-Einstufung: [Limited Risk]
├─ Kunden-Information: [Datum, Methode]
└─ DVA-Prüfung: [Status]

Schritt 2: Produktion
├─ Verwendete Modelle: [Midjourney v6, GPT-4, etc.]
├─ Prompts: [Log-Datei]
├─ Outputs: [Anzahl, Varianten]
└─ Menschliche Review: [Reviewer, Datum, Ergebnis]

Schritt 3: Post-Produktion
├─ KI-Enhancement: [Ja/Nein, Details]
├─ Menschliche Nachbearbeitung: [Details]
└─ Final Review: [Reviewer, Datum, Ergebnis]

Schritt 4: Lieferung
├─ AI-Usage-Report: [Anlage]
├─ Labeling: [Status]
├─ Kunden-Freigabe: [Datum, Name]
└─ Compliance-Check: [Datum, Name]
```

5. DSGVO-Konformität

5.1 Datenverarbeitung bei KI-Workflows

Daten-Typ	Verarbeitung	Rechtsgrundlage	Maßnahme
Kunden-Daten (Briefings, Brand-Guidelines)	KI-Input	Vertragserfüllung (Art. 6 Abs. 1 lit. b)	DVA, Datenminimierung
Generierte Bilder (mit Personen)	KI-Output	Einwilligung (Art. 6 Abs. 1 lit. a)	Explizite Einwilligung, Löschfristen
Trainingsdaten (keine personenbezogenen Daten)	Modell-Training	Nicht anwendbar	Keine personenbezogenen Daten verwendet
Meta-Daten (Performance-Daten)	Analyse	Berechtigtes Interesse (Art. 6 Abs. 1 lit. f)	Anonymisierung, DVA

5.2 Datenverarbeitungsvereinbarung (DVA)

Pflichten des Auftragsverarbeiters (MIRROU):

- Verarbeitung nur nach Weisung des Verantwortlichen (Kunde)

- Sicherheit der Verarbeitung (Art. 32 DSGVO)
- Geheimhaltungspflicht
- Unterauftragsverarbeiter nur mit Genehmigung
- Löschung oder Rückgabe nach Vertragsende
- Unterstützung bei DSFA und Betroffenenrechten

Standard-DVA-Klauseln:

- Anlage A: Verarbeitungsgegenstand, -dauer, -art, -zweck
 - Anlage B: Technische und organisatorische Maßnahmen (TOMs)
 - Anlage C: Unterauftragsverarbeiter-Liste
-

6. Kunden-Kommunikation

6.1 Informationspflichten

Vor Projektbeginn:

- Schriftliche Information über KI-Nutzung und deren Umfang
- Erklärung der Labeling-Pflichten und -Standards
- Hinweis auf EU AI Act-Compliance
- Übergabe der DVA (falls anwendbar)

Während des Projekts:

- Regelmäßige Updates über KI-Usage (wöchentlich im Retainer)
- Bei Änderungen: sofortige Information

Nach Projektabschluss:

- AI-Usage-Report mit allen relevanten Details
- Compliance-Bestätigung
- Audit-Trail (auf Anfrage)

6.2 AI-Usage-Report (Template)

```
MIRROU — AI-Usage-Report
Projekt: [Name]
Kunde: [Name]
Zeitraum: [Datum - Datum]

1. Verwendete KI-Systeme
  • [Modell-Name, Version, Anbieter]
  • [Zweck der Nutzung]

2. KI-generierte Inhalte
  • Anzahl Assets: [X]
```

- KI-Anteil pro Asset: [Durchschnitt %]
- Labeling-Status: [100% korrekt]

3. Menschliche Nachbearbeitung

- Review-Prozess: [Beschreibung]
- Freigabe durch: [Name, Datum]

4. Compliance-Status

- EU AI Act: [Konform]
- DSGVO: [Konform]
- Data Act: [Konform]

5. Empfehlungen

- [Falls relevant]

Unterschrift Compliance Officer: _____

Datum: _____

7. Risiko-Management

7.1 KI-Risiko-Matrix

Risiko	Wahrscheinlichkeit	Impact	Mitigation
Fehlerhaftes Labeling	Niedrig	Hoch	Automatisierte Checks, menschliche Review
Kunde verweigert AI-Usage-Report	Niedrig	Mittel	Vertragsklausel, Compliance-Pflicht
Regulatorische Änderung	Mittel	Hoch	Monitoring, quartalsweise Review
KI-Modell-Änderung (neue Version)	Hoch	Mittel	Version-Pinning, Change-Management
Datenleck bei KI-Anbieter	Niedrig	Hoch	DVA mit Anbietern, Verschlüsselung

7.2 Eskalations-Prozess

Level 1: KI-Operator erkennt Compliance-Problem

- Sofortige Pausierung des Outputs
- Benachrichtigung Creative Lead
- Dokumentation des Vorfalls

Level 2: Creative Lead bestätigt Problem

- Benachrichtigung Compliance Officer
- Risiko-Assessment
- Entscheidung: Weiterarbeit, Korrektur, oder Stopp

Level 3: Compliance Officer erkennt schwerwiegendes Problem

- Sofortige Stopp aller relevanten Aktivitäten

- Benachrichtigung Kunde
- Externe Rechtsberatung (falls erforderlich)
- Dokumentation und Lessons Learned

8. Schulung & Awareness

8.1 Onboarding-Schulung (neue Mitarbeiter)

Modul	Dauer	Inhalt	Verantwortlich
EU AI Act Grundlagen	2 Std.	Verordnung, Anwendbarkeit, Pflichten	Compliance Officer
DSGVO für Kreative	1 Std.	Datenverarbeitung, DVA, Betroffenenrechte	Compliance Officer
KI-Tool-Training	2 Std.	Prompt-Engineering, Output-Review, Labeling	KI-Operator
Case Studies	1 Std.	Best Practices, Fehlerbeispiele, Lessons Learned	Creative Lead
Prüfung	30 Min.	Quiz, Bestehensgrenze: 80%	Compliance Officer

8.2 Kontinuierliche Schulung

- **Monatlich:** 30 Min. Update zu regulatorischen Änderungen
- **Quartalsweise:** 2 Std. Deep-Dive zu neuen Tools oder Risiken
- **Jährlich:** 4 Std. Refresh-Training mit Zertifizierung

9. Audit-Readiness

9.1 Interne Audits

Frequenz	Umfang	Verantwortlich
Monatlich	Stichproben-Check: 10% der Assets	KI-Operator
Quartalsweise	Vollständige Review eines Projekts	Compliance Officer
Jährlich	Externe Audit (Wirtschaftsprüfer oder Rechtsanwalt)	CEO

9.2 Externe Audits

Vorbereitung:

- Alle Dokumentationen vollständig und aktuell
- Audit-Trail für alle Projekte der letzten 3 Jahre

- Mitarbeiter verfügbar für Interviews
- Technische Systeme zugänglich

Häufige Prüfpunkte:

- Vollständigkeit der KI-System-Beschreibung
- Korrektheit des Labelings
- Vollständigkeit der menschlichen Reviews
- Einhaltung der DVA-Pflichten
- Aktualität der Schulungsnachweise

10. Kontakt & Ressourcen

Ressource	Kontakt	Nutzung
Compliance Officer	[E-Mail]	Alle Compliance-Fragen, Audit-Readiness
KI-Operator	[E-Mail]	Technische Fragen, Tool-Probleme
Externer Rechtsberater	[Anwaltskanzlei]	Komplexe rechtliche Fragen, Streitfälle
EU AI Act Text	eur-lex.europa.eu	Primärquelle
BSI-Leitlinien	bsi.bund.de	Nationale Umsetzungshilfen

Dokumenten-Status:  Final **Nächste Review:** Bei regulatorischen Änderungen oder quartalsweise
Verantwortlich: Compliance Officer & Legal Counsel